

A THREE-PART SERIES · APRIL–MAY 2026

Who Pays When the Agent Gets It Wrong?

Three gaps in agentic AI payments — the liability vacuum across rails, the identity infrastructure that can't name the actor, and the market structure forming around both.

PART 1

The Liability Gap

PART 2

The Identity Problem

PART 3

Fast Tech, Slow Law

Three gaps, one inversion.

Part 1 maps consumer-protection gaps across five payment rails. Part 2 asks: how can a bank assign liability when it can't identify the actor? Part 3 covers the system level — market structure, regulatory limbo, and who actually holds the risk.

PART 1 April 25, 2026

The Liability Gap

Consumer protection isn't one gap. It's five — one per payment rail — and the gaps are worst on the rails agents are most incentivized to use.

PART 2 April 25, 2026

The Identity Problem

CIP was written for natural persons and legal entities. An AI agent is neither — and no banking law has a category for it.

PART 3 May 16, 2026

Fast Tech, Slow Law

A three-tier banking market is forming around AAI, Sec 1033 is enjoined, and flagship deployments are underperforming.

PART 1 · LIABILITY · APRIL 25, 2026

The Liability Gap

Consumer protection for agent-initiated payments isn't a single gap — it's five different gaps, one per payment rail. And the gaps are worst on the rails agentic systems are most incentivized to use.

THE QUESTION

Your AI agent moves money. Something goes wrong.

The answer to “who is liable?” has no clean form under current U.S. law. It depends almost entirely on which payment rail the transaction traveled — and on the rails agentic transactions are most likely to flow, the answer points toward you.

SCENARIO 01

Wrong flight, non-refundable

The assistant books the wrong city, the wrong dates, the wrong fare class. Non-refundable. The merchant did exactly what the request said.

SCENARIO 02

The same bill, twice

A retry loop, an idempotency miss, a clock-drift bug. The second payment cleared. The account holder didn't notice for forty days.

SCENARIO 03

Spoofed merchant, \$800 gone

The agent was deceived by a prompt-injected page and sent \$800 to the wrong account. The destination wallet is offshore and irrevocable.

The agents know how to route. The law doesn't know how to follow.

Four words at the center of the problem.

Reg E's consumer protections — the \$50/\$500 liability caps for unauthorized electronic fund transfers — exclude any transfer covered by a single statutory exception. It was drafted for a different scenario.

THE EXCEPTION

...a transfer “initiated by a person to whom the consumer has **furnished the access device.**”

DESIGNED FOR

You hand your debit card to your spouse. Your spouse makes purchases. You later claim you didn't authorize them. Congress said: that isn't

NOW APPLIES TO

You grant an AI assistant API-level access. You have arguably “furnished” it the access device. No federal court has adjudicated this. The

Consumer protection by payment rail.

Protection erodes as you move down — and disappears on the newest two. Credit cards still have meaningful recourse. RTP, FedNow, and stablecoins offer almost none.

RAIL	GOVERNING LAW	KEY GAP FOR AGENTIC TRANSACTIONS
Credit card	TILA / Reg Z + network rules	No agent-specific chargeback reason code; zero-liability may exclude delegated transactions.
Debit / ACH	EFTA / Reg E + Nacha rules	The “furnished access device” exception is the fatal structural gap; tiered caps may be voided.
Wire	UCC 4A; EFTA unsettled	Historically no consumer recourse; <i>NY v. Citibank</i> is the pivotal pending Second Circuit signal.
RTP / FedNow	UCC 4A + Reg E (in theory)	Speed + irrevocability is the highest-risk combination — no undo, no reversal mechanism.
Stablecoin (post-GENIUS)	GENIUS Act; Reg E inapplicable	No federal floor for fraud recovery; wallet T&Cs only. ²⁵ The largest gap.

Best protected — with caveats.

Credit cards have the most developed dispute infrastructure. Debit and ACH share a statutory framework but a worse fit for delegated, asynchronous authorization.

Credit card

RELATIVELY BEST PROTECTED

TILA / Reg Z gives a \$50 statutory cap. Network zero-liability policies typically reduce that to zero. §1666 billing-error procedures plus chargeback infrastructure provide meaningful recourse.

CAVEAT • No agent-specific chargeback reason code exists. Disputes flow through card-not-present

Debit / ACH

STRUCTURALLY EXPOSED

EFTA / Reg E imposes tiered \$50/\$500/unlimited liability based on notice timing. The reporting clock assumes you review transactions quickly — a poor fit for delegation.

CAVEAT • Granting an agent account access may furnish the access device. If a court agrees, the entire / 25 liability cap disappears for agent-initiated debit and

No undo button.

UCC 4A treats wires as institutional instruments with very limited consumer recourse. Instant payments inherit that framework and add speed and finality on top — a structurally hostile environment for any kind of error correction, agentic or otherwise.

THE PENDING SIGNAL

New York v. Citibank

SDNY Judge Oetken held that EFTA can reach the customer-to-bank leg of online-initiated wires. Citibank appealed. The Second Circuit ruling, expected late 2026, applies directly to agent-initiated pushes on the same infrastructure.

The single most important near-term legal signal in

THE WORST STRUCTURAL FIT

RTP & FedNow

Designed for speed and finality. Transactions settle in seconds and are irrevocable. No chargeback mechanism. An agentic system that misroutes can execute dozens of transfers before any flag fires.

The “furnished access device” exception still applies.

Strong on reserves. Silent on consumers.

Signed July 18, 2025, the GENIUS Act is the first U.S. federal framework for payment stablecoins. It does real work on reserves and chartering. It does not establish any consumer-protection floor for fraud recovery.

WHAT THE ACT ESTABLISHES

- 100% reserves in cash or short-term Treasuries
- Monthly attestation requirements
- Dual federal-state chartering
- First-priority bankruptcy claim for holders

WHAT IT DOESN'T

- EFTA applicability is silent
- No mandatory redemption timeline
- No error-resolution mechanism
- No AAI-specific authorization or wallet rules

Agents will route to the weakest rail.

The rails with the weakest consumer protection are the ones that offer the most attractive economic terms for autonomous systems — lower fees, faster settlement, programmable conditions. Routing risk and liability risk point in the same direction.

RAIL	CONSUMER PROTECTION	WHY AGENTS PREFER IT
Credit card	Strongest	High interchange, slow settlement, mature dispute path — least attractive to autonomous routing.
Debit / ACH	Tiered, exposed	Lower interchange than cards; reporting clock is a poor fit for delegated review.
RTP / FedNow	Effectively none	Sub-second settlement, programmable conditions, near-zero per-transaction cost.
Stablecoin	No federal floor	Programmable money, 24/7 settlement, lowest fees, no Reg E exposure to anyone in the chain. ¹⁰ / 25

Banks Don't Know Who Your AI Agent Is

Before you can allocate liability for a bad transaction, you need to know who you're dealing with. Banks have a legal obligation to answer that question. The law doesn't contemplate the entity type they're being asked to identify.

Know your customer — but which entity?

Every federally regulated bank must collect and verify four minimum identifying data elements before opening an account. The rule was written for two entity types. Both are defined; neither is software.

ELEMENT 01 Full legal name	ELEMENT 02 Date of birth	ELEMENT 03 Residential address	ELEMENT 04 Taxpayer ID
--	--	--	--

ENTITY TYPE 01

Natural persons

Defined by the PATRIOT Act (2001) and joint rulemaking in 2003. Humans with documentary or non-documentary identity verification.

ENTITY TYPE 02

Legal entities

Corporations, LLCs, partnerships. Verified via formation documents and beneficial-ownership disclosures.

THE GAP

No DOB. No address. No TIN.

An AI agent is neither a natural person nor a legal entity. It is software operating on behalf of a principal — but which principal, and with what scope, may not be determinable from the transaction. No U.S. banking law has an AAI customer category.

THE DOWNSTREAM CONSEQUENCE

If a bank can't identify the agent as a distinct party, the only party it knows is the account holder. The entire dispute pathway runs through them — regardless of whether they instructed the specific transaction.

This is why the “furnished access device” exception in Regulation E is so consequential. The bank sees a transaction originating from a known account, with no record of which agent initiated it or under what authorization. Identity and liability collapse together.

Examiner-by-examiner extension.

If CIP is the account-opening framework, FFIEC is the ongoing-access framework. The 2021 guidance was written for human users and managed system credentials. It predates autonomous agents as an entity class.

WHAT THE GUIDANCE COVERS

Service accounts and device credentials enterprises register and manage centrally. Per-credential identity, access controls, and risk assessments — the “applications and devices” category.

WHAT EXAMINERS ARE DOING

Stretching the same category to cover AI agents — no new rulemaking, no comment period. Each examiner applies their own reading. Different districts produce different findings for materially similar deployments.

Banks have no reliable way to know in advance whether their agent

Identity-first vs. intent-first.

The card networks have moved into the identity vacuum with frameworks that represent genuinely different design philosophies about what “agent identity” means. Both questions matter; neither framework has been tested in examination or court.

VISA · WITH CLOUDFLARE · OCT 2025

Trusted Agent Protocol

IDENTITY-FIRST

An agent registers with Visa and receives a durable credential. At transaction time it signs the HTTP request using RFC 9421 HTTP Message Signatures, attesting agent + consumer recognition + tokenized payment binding.

MASTERCARD · WITH GOOGLE · MAR 2026

Agent Pay / Verifiable Intent

INTENT-FIRST

The issuing bank registers the agent and issues short-lived SD-JWT credentials specifying merchant category codes, spending caps, time windows, and additional first-class authorization limits. Certifies the scope, not just the actor.

The invisible agent.

Both card-network frameworks assume the agent is a known, registerable entity. That assumption breaks for a growing category of agents that no enterprise deployed.

THE CATEGORY

Browser agents built individually with tools like Yutori's Navigator or Claude's Chrome integration. Personally configured, unique per user, with no enrollment in any financial network or developer console.

THE FAILURE MODE

No agent identity record. No registered authorization scope. No enrollment event to produce in a dispute. The bank can't distinguish "account holder authorized this" from "an agent exceeded its understood scope."

The "furnished access device" exposure is worst precisely for the agents becoming most accessible to ordinary consumers.

Widely adopted ≠ safe for core banking.

MCP standardizes how agents connect to financial data sources. Plaid, Modern Treasury, and LSEG all ship MCP servers. The security research is not reassuring.

7.2%

of 1,899 OS MCP servers had
general security vulnerabilities

5.5%

exhibited MCP-specific tool
poisoning vulnerabilities

9.8

CVSS for CVE-2026-33032
(Nginx-ui MCP)

JPMORGAN'S CHIEF ANALYTICS OFFICER, DEREK WALDRON

*"Access management and entitlements of agents" is an unsolved problem
"the industry needs to uplift"*

What good design looks like.

The most useful design patterns for agentic authentication come from jurisdictions and sectors that have already grappled with delegated authority at scale. None of the U.S. analogs exist.

EU · EIDAS 2.0

Government-rooted wallets

Every member state deploys digital identity wallets to all eligible citizens by Dec 2026. An agent can present a cryptographically signed, government-issued credential establishing the principal and the

EU · PSD3 / PSR

Delegated SCA as regulated outsourcing

A consumer can authorize a third-party provider to authenticate transactions on their behalf, within a defined scope, with clear regulatory accountability. The legal foundation U.S. law currently doesn't

HEALTHCARE · SMART ON FHIR

Resource-level scope syntax

Machine-readable, auditable permission grants:
agent/account.transact.limit=\$500.merchant=grocery.
Specific, constrained, revocable. The pattern is mature; no U.S. bank has published a production version.

Fast Tech, Slow Law, Narrowing Merchants

A three-tier banking market is forming around AAI. Open banking got enjoined at the worst possible moment. Flagship deployments have underperformed. The U.S. is betting on private ordering at precisely the moment other jurisdictions are going the other direction.

Three tiers — and a fourth that fits none.

Something structural is happening to the U.S. banking market, and it has less to do with AI capability than with data access and regulatory position. A fourth category is growing outside the institutional market entirely.

TIER 1

Money-center banks

JPMorgan Chase, Citi, BofA

Building proprietary AAI and monetizing external data access. JPM charges for ~1.89B monthly third-party data requests.

TIER 2

Fintechs & neobanks

Chime, SoFi, Block, Plaid

AAI-native through Plaid, MX, Stripe. Now paying Tier 1 banks they're competing with for data access.

TIER 3

Community banks

Credit unions, banks < \$10B

~62% struggle to integrate multi-source data. Lobbying for an open-banking exemption. Falling further behind.

OUTSIDE THE TIERS

Consumer DIY agents

Yutori n1, Claude Chrome

No enrollment, no registration, no liability framework. Volume is small but the tooling is becoming accessible.

Section 1033 enjoined at the worst moment.

The CFPB's 2024 Personal Financial Data Rights rule was the statutory floor for agentic AI: a consumer's legal right to access their own financial data in machine-readable form. The CFPB abandoned its defense.

THE RULING

Judge Reeves granted a preliminary injunction Oct 29, 2025, staying compliance deadlines. The court held that “representative” under § 1033 likely requires a fiduciary-like relationship — which would exclude commercial third-party aggregators.

THE IMPLICATION

If that reading holds in a revised rule, AI agents routed through aggregators lose any statutory right of access — dependent entirely on whatever commercial terms Tier 1 banks offer. Federal consumer protection law plays no role.

WHAT THE DEPLOYMENTS PRODUCED

ChatGPT Instant Checkout — pullback.

Launched September 29, 2025 with Etsy, Shopify, Walmart, Target, and Expedia via the Stripe-built Agentic Commerce Protocol. By March 2026 it was redirecting users to merchant apps rather than completing checkout natively.

12–30

Shopify merchants live out of millions available

0

state sales-tax remittance infrastructure built

last

Forrester rank: completing a purchase in an AI answer engine

THE MISSING DATA

No error rate, dispute rate, or fraud rate data has been published for any major deployment. Until independent dispute-rate data exists, the risk profile of agentic payments is unknown.

Checkouts are for humans.

Shopify's July 2025 robots.txt update is the industry's most-cited merchant control model. It reflects what happens downstream when the authorization ambiguity goes unresolved: merchants block by default.

SHOPIFY · ROBOTS.TXT · JULY 2025

“Checkouts are for humans. Automated scraping, ‘buy-for-me’ agents, or any end-to-end flow that completes payment without a **final review step** is not permitted.”

Sanctioned exceptions flow through Shopify's Agentic Storefronts Supplemental Terms — ChatGPT, Copilot, Google AI Mode, Gemini, Perplexity via PayPal. Everyone else is treated as agentic traffic to be blocked. Without a reliable proof-of-authorization model,

Five developments that move this forward.

01 Second Circuit ruling in NY v. Citibank

Determines whether EFTA reaches the customer-to-bank leg of online-initiated wires. Reasoning applies directly to agent-initiated pushes on RTP and FedNow. The single most important near-term legal signal.

02 CFPB's revised Section 1033 rule

Resolves whether AI agents routed through aggregators qualify as statutory “representatives.” If the fiduciary reading holds, Tier 1 banks' data-fee advantage becomes structural and permanent.

03 GENIUS Act implementation rules

OCC, FDIC, Treasury NPRMs expected late 2026–early 2027. The question is whether any AAI-specific wallet-custody or authorization standards appear, or whether the consumer-protection gaps remain open.

04 First published fraud and dispute-rate data

From Visa Intelligent Commerce, Mastercard Agent Pay, or Google AP2 pilots. Actual numbers will force a reckoning that the current absence of data is preventing.

05 FDX Agentic AI Call for Input

Response deadline May 29, 2026. As the CFPB-recognized standard-setting body, FDX's specifications carry weight in

The technology is real. The protection isn't keeping pace.

PART 1

Liability vacuums

Five gaps, one per rail. Worst on RTP, FedNow, and stablecoins — precisely where agents have the strongest incentive to route.

PART 2

No customer category

CIP doesn't fit. FFIEC stretches. Card-network frameworks help but exclude DIY agents. The EU has the infrastructure; the U.S. doesn't.

PART 3

Uneven risk

Tier 1 banks benefit from uncertainty as a moat. Community banks and their customers carry the gaps. Consumer DIY agents fit no framework.

When something goes wrong, and something will go wrong, do the people most exposed to the consequence have any meaningful recourse?